# FICHE 19 - GÉRER LES INCIDENTS ET LES VIOLATIONS

### Prévoir les procédures pour gérer les incidents et réagir en cas de violation de données (atteinte à la confidentialité, l'intégrité ou la disponibilité).

Il convient d'être préparé à l'éventualité d'un incident pour intervenir à temps et de manière appropriée, en intégrant l'objectif de limiter les effets pour les personnes dont les données sont concernées. Le responsable de traitement peut être amené à notifier la CNIL ou informer les personnes concernées de l'incident en fonction du risque pour celles-ci.

## Les précautions élémentaires

- **Analyser régulièrement les traces collectées** (voir la fiche n°16 - Tracer les opérations).
- S'assurer que **les gestionnaires du dispositif de gestion des traces** (qu'ils soient internes ou externes) **notifient le responsable de traitement, dans les plus brefs délais, en cas d'anomalie ou d'incident de sécurité**.
- Diffuser à tous les utilisateurs, internes comme externes, **la conduite à tenir et la liste des personnes à contacter en cas d'incident de sécurité ou de survenance d'un évènement inhabituel** touchant aux systèmes d'information et de communication de l'organisme. **Sensibiliser les utilisateurs** à l'importance de signaler tout évènement suspect.
- Établir des procédures détaillant les dispositifs de génération et de remontée des alertes des différentes sources (ex. : automatiques, par les utilisateurs), leur traitement et les actions à mener en cas d'incident avéré (ex. : personnes à contacter, actions pour circonscrire l'incident en fonction de sa nature). Inclure la gestion des violations de données dans le processus de gestion des incidents. **Définir des critères de qualification d'un incident en violations de données**.
- **Évaluer le risque, pour les personnes, engendré par la violation** en tenant compte de la gravité et de la probabilité des conséquences que la violation pourrait avoir sur leurs droits et libertés.
- **Tenir un registre interne de toutes les violations de données personnelles**.
- **Notifier[80] à la CNIL, dans les 72 heures (tel que prévu par le RGPD), les violations présentant un risque pour les droits et libertés des personnes et**, en cas de de risque élevé et sauf exception prévue par le RGPD[81], **informer les personnes concernées** pour qu'elles puissent en limiter les conséquences[82].

## Ce qu'il ne faut pas faire

- Attendre que les personnes concernées ou des tiers détectent un incident et le signalent.
- Omettre l'analyse des risques qu'une violation de données personnelles pourrait avoir pour les droits et libertés des personnes.
- Attendre d'avoir des informations précises pour notifier la CNIL alors qu'il est clairement établi qu'une violation s'est produite. Les notifications de données peuvent être transmises en deux temps : une initiale, dans les 72h, puis une complémentaire ensuite si nécessaire.

---

80 La procédure de notification est détaillée sur le site de la CNIL (voir « Notifier une violation de données personnelles », cnil.fr).

81 Articles 33 et 34 du RGPD.

82 L'obligation de notification de violation de données personnelles ne dédouane pas le responsable de ses potentielles autres obligations de remontée d'incident (voir « Notifications d'incidents de sécurité aux autorités de régulation : comment s'organiser et à qui s'adresser ? », cnil.fr).